# Chapter 5 / Capítulo 5

## Self-assessment / Autoevaluación

**English: CISA self-assessment questions support the content in this manual and provide an understanding of the type and structure of questions that typically appear on the exam. Often a question will require the candidate to choose the MOST likely or BEST answer among the options provided. Please note that these questions are not actual or retired exam items. Please see section About This Manual for more guidance regarding practice questions.**

**Español: Las preguntas de autoevaluación CISA complementan el contenido de este manual y permiten comprender el tipo y la estructura de las preguntas que suelen aparecer en el examen. A menudo se pide elegir la respuesta MÁS probable o la MEJOR entre las opciones. Estas preguntas no son preguntas reales ni retiradas del examen. Consulte la sección Acerca de este manual para obtener más orientación sobre las preguntas de práctica.**

Fuente: CISA Official Review Manual, ISACA. Texto y clave proporcionados por el usuario. Traducción no oficial. Se incluyen las explicaciones completas de todas las alternativas. Los guiones son explicaciones propias.

# Question 1 / Pregunta 1

**English: An IS auditor reviewing the configuration of a signature-based intrusion detection system (IDS) would be MOST concerned if which of the following were discovered?**

A. Auto-update is turned off.

B. Scanning for application vulnerabilities is disabled.

C. Analysis of encrypted data packets is disabled.

D. The IDS is placed between the demilitarized zone (DMZ) and the firewall.

**Español: Al revisar la configuración de un sistema de detección de intrusiones (IDS) basado en firmas, ¿cuál de los siguientes hallazgos preocuparía MÁS al auditor de SI?**

A. La actualización automática está desactivada.

B. El análisis de vulnerabilidades de las aplicaciones está desactivado.

C. El análisis de paquetes de datos cifrados está desactivado.

D. El IDS se encuentra entre la zona desmilitarizada (DMZ) y el firewall.

## Correct answer / Respuesta correcta: A

**Explanation of every option / Justificación de cada alternativa**

### A. Correct / Correcta

**English:** The most important aspect of a signature-based intrusion detection system (IDS) is its ability to protect against known (signature) intrusion patterns. Such signatures are provided by the vendor and are critical to protecting an enterprise from outside attacks.

**Español:** El aspecto más importante de un IDS basado en firmas es su capacidad para proteger contra patrones conocidos de intrusión. El proveedor proporciona estas firmas y son fundamentales para proteger a la empresa de ataques externos.

### B. Incorrect / Incorrecta

**English:** One of the key disadvantages of an IDS is its inherent inability to scan for vulnerabilities at the application level.

**Español:** Una de las principales desventajas de un IDS es su incapacidad inherente para analizar vulnerabilidades a nivel de aplicación.

### C. Incorrect / Incorrecta

**English:** An IDS cannot break encrypted data packets to identify the source of the incoming traffic.

**Español:** Un IDS no puede descifrar paquetes de datos cifrados para identificar el origen del tráfico entrante.

### D. Incorrect / Incorrecta

**English:** A demilitarized zone (DMZ) is an internal network segment in which systems (e.g., a web server) accessible to the public are housed. In order to provide the greatest security and efficiency, an IDS should be placed behind the firewall so that it will detect only those attacks/ intruders that enter the firewall.

**Español:** Una DMZ es un segmento de red interna donde se alojan sistemas accesibles al público, como un servidor web. Para proporcionar la mayor seguridad y eficiencia, el IDS debe colocarse detrás del firewall, de modo que detecte únicamente los ataques o intrusos que lo atraviesen.

## Suggested speaking script / Guion sugerido

**English:** I choose A because a signature-based IDS depends on current signatures to recognize known attacks.

**Español:** Elegiría la A porque un IDS basado en firmas necesita firmas actualizadas para reconocer ataques conocidos.

# Question 2 / Pregunta 2

**English: Which of the following BEST provides access control to payroll data being processed on a local server?**

A. Logging access to personal information

B. Using separate passwords for sensitive transactions

C. Using software that restricts access rules to authorized staff

D. Restricting system access to business hours

**Español: ¿Cuál proporciona el MEJOR control de acceso a los datos de nómina procesados en un servidor local?**

A. Registrar el acceso a información personal.

B. Utilizar contraseñas independientes para transacciones sensibles.

C. Utilizar software que restrinja las reglas de acceso al personal autorizado.

D. Restringir el acceso al sistema al horario laboral.

## Correct answer / Respuesta correcta: C

**Explanation of every option / Justificación de cada alternativa**

### A. Incorrect / Incorrecta

**English:** Logging access to personal information is a good control in that it will allow access to be analyzed if there is concern over unauthorized access. However, it will not prevent access.

**Español:** Registrar el acceso a información personal es un buen control porque permite analizarlo si se sospecha de accesos no autorizados. Sin embargo, no impide el acceso.

### B. Incorrect / Incorrecta

**English:** Restricting access to sensitive transactions will restrict access only to some of the data. It will not prevent access to other data.

**Español:** Restringir el acceso a transacciones sensibles limita el acceso solo a una parte de los datos. No evita el acceso a otros datos.

### C. Correct / Correcta

**English:** The server and system security should be defined to allow only authorized staff members access to information about the staff whose records they handle on a day-to-day basis.

**Español:** La seguridad del servidor y del sistema debe definirse para permitir que únicamente el personal autorizado acceda a la información de los empleados cuyos registros maneja diariamente.

### D. Incorrect / Incorrecta

**English:** Restricting system access to business hours would only affect when unauthorized access could occur and would not prevent such access at other times. It is important to consider that the data owner is responsible for determining who is allowed access via the written software access rules.

**Español:** Restringir el acceso al horario laboral solo afecta cuándo podría ocurrir un acceso no autorizado y no lo evita en otros momentos. Es importante considerar que el propietario de los datos determina quién puede acceder mediante reglas de acceso escritas en el software.

## Suggested speaking script / Guion sugerido

**English:** I choose C because permissions should restrict payroll data to the staff authorized to handle those records.

**Español:** Elegiría la C porque los permisos deben limitar los datos de nómina al personal autorizado para manejar esos registros.

# Question 3 / Pregunta 3

**English: An information systems (IS) auditor has just completed a review of an organization that has a mainframe computer and two database servers where all production data reside. Which of the following weaknesses would be considered the MOST serious?**

A. The security officer also serves as the database administrator.

B. Password controls are not administered over the two database servers.

C. There is no business continuity plan (BCP) for the mainframe system's noncritical applications.

D. Most local area networks (LANs) do not back up file-server-fixed disks regularly.

**Español: Un auditor de SI acaba de revisar una organización con una computadora central (mainframe) y dos servidores de bases de datos que contienen todos los datos de producción. ¿Qué debilidad sería la MÁS grave?**

A. El responsable de seguridad también administra la base de datos.

B. No se administran controles de contraseñas en los dos servidores de bases de datos.

C. No existe un plan de continuidad del negocio (BCP) para las aplicaciones no críticas del mainframe.

D. La mayoría de las redes locales (LAN) no respaldan regularmente los discos fijos de los servidores de archivos.

## Correct answer / Respuesta correcta: B

**Explanation of every option / Justificación de cada alternativa**

### A. Incorrect / Incorrecta

**English:** The security officer serving as the database administrator, while a control weakness, does not carry the same disastrous impact as the absence of password controls.

**Español:** Que el responsable de seguridad también administre la base de datos es una debilidad de control, pero no tiene el mismo impacto desastroso que la ausencia de controles de contraseñas.

### B. Correct / Correcta

**English:** The absence of password controls on the two database servers, where production data resides, is the most critical weakness.

**Español:** La ausencia de controles de contraseñas en los dos servidores de bases de datos, donde residen los datos de producción, es la debilidad más crítica.

### C. Incorrect / Incorrecta

**English:** Having no business continuity plan (BCP) for the mainframe system's noncritical applications, while a control weakness, does not carry the same disastrous impact as the absence of password controls.

**Español:** No disponer de un BCP para las aplicaciones no críticas del mainframe es una debilidad de control, pero no tiene el mismo impacto desastroso que la ausencia de controles de contraseñas.

### D. Incorrect / Incorrecta

**English:** Local area networks (LANs) not backing up regularly, while a control weakness, does not carry the same disastrous impact as the absence of password controls.

**Español:** No realizar respaldos regulares de las LAN es una debilidad de control, pero no tiene el mismo impacto desastroso que la ausencia de controles de contraseñas.

## Suggested speaking script / Guion sugerido

**English:** I choose B because production data need effective authentication controls to prevent unauthorized access.

**Español:** Elegiría la B porque los datos de producción necesitan controles de autenticación eficaces que eviten accesos no autorizados.

# Question 4 / Pregunta 4

**English: An organization is proposing to install single sign-on (SSO) to give access to all systems. The organization should be aware that:**

A. maximum unauthorized access would be possible if a password were disclosed.

B. user access rights would be restricted by the additional security parameters.

C. the security administrator's workload would increase.

D. user access rights would be increased.

**Español: Una organización propone instalar inicio de sesión único (SSO) para acceder a todos los sistemas. Debe tener en cuenta que:**

A. Si se divulga una contraseña, podría producirse el máximo acceso no autorizado.

B. Los derechos de acceso se restringirían mediante parámetros adicionales de seguridad.

C. Aumentaría la carga de trabajo del administrador de seguridad.

D. Aumentarían los derechos de acceso de los usuarios.

## Correct answer / Respuesta correcta: A

**Explanation of every option / Justificación de cada alternativa**

### A. Correct / Correcta

**English:** If a password is disclosed when single sign-on (SSO) is enabled, there is a risk that unauthorized access to all systems will be possible.

**Español:** Si se divulga una contraseña cuando el SSO está habilitado, existe el riesgo de que sea posible acceder sin autorización a todos los sistemas.

### B. Incorrect / Incorrecta

**English:** User access rights should remain unchanged by SSO, as additional security parameters might not be implemented.

**Español:** Los derechos de acceso de los usuarios deberían mantenerse sin cambios con SSO, ya que podrían no implementarse parámetros adicionales de seguridad.

### C. Incorrect / Incorrecta

**English:** One of the intended benefits of SSO is the simplification of security administration.

**Español:** Uno de los beneficios previstos del SSO es simplificar la administración de seguridad.

### D. Incorrect / Incorrecta

**English:** One of the intended benefits of SSO is the unlikelihood of an increased workload.

**Español:** Uno de los beneficios previstos del SSO es que resulta poco probable que aumente la carga de trabajo.

**Nota del material original:** La explicación D habla de carga de trabajo, aunque la opción D habla de derechos de acceso. Se conserva la diferencia del original.

## Suggested speaking script / Guion sugerido

**English:** I choose A because compromising the SSO password could expose every system accessible through that account.

**Español:** Elegiría la A porque comprometer la contraseña del SSO podría exponer todos los sistemas accesibles mediante esa cuenta.

# Question 5 / Pregunta 5

**English: When reviewing an implementation of a Voice over Internet Protocol (VoIP) system on a corporate wide area network, an IS auditor should expect to find:**

A. traffic engineering.

B. an integrated services digital network (ISDN) data link.

C. wired equivalent privacy encryption of data.

D. analog phone terminals.

**Español: Al revisar la implementación de voz sobre protocolo de Internet (VoIP) en una red corporativa de área amplia, el auditor de SI debería encontrar:**

A. Ingeniería de tráfico.

B. Un enlace de datos de red digital de servicios integrados (ISDN).

C. Cifrado de datos WEP.

D. Terminales telefónicos analógicos.

## Correct answer / Respuesta correcta: A

**Explanation of every option / Justificación de cada alternativa**

### A. Correct / Correcta

**English:** To ensure that quality of service (QoS) requirements is achieved, the Voice over Internet Protocol (VoIP) service over the wide area network should be protected from packet losses, latency or jitter. To reach this objective, network performance can be managed to provide QoS and class of service support using statistical techniques, such as traffic engineering.

**Español:** Para cumplir los requisitos de calidad de servicio (QoS), el servicio VoIP sobre la red de área amplia debe protegerse contra pérdidas de paquetes, latencia y variación del retardo (jitter). Para ello, puede gestionarse el rendimiento de la red con soporte de QoS y clase de servicio mediante técnicas estadísticas, como la ingeniería de tráfico.

### B. Incorrect / Incorrecta

**English:** The standard bandwidth of an integrated services digital network (ISDN) data link would not provide the QoS required for corporate VoIP services.

**Español:** El ancho de banda estándar de un enlace ISDN no proporcionaría la QoS necesaria para servicios VoIP corporativos.

### C. Incorrect / Incorrecta

**English:** Wired equivalent privacy is an encryption scheme related to wireless networking.

**Español:** WEP es un esquema de cifrado relacionado con redes inalámbricas.

### D. Incorrect / Incorrecta

**English:** VoIP phones are usually connected to a corporate local area network (LAN) and are not analog.

**Español:** Los teléfonos VoIP suelen conectarse a una LAN corporativa y no son analógicos.

## Suggested speaking script / Guion sugerido

**English:** I choose A because voice traffic needs stable delivery with low delay and packet loss.

**Español:** Elegiría la A porque el tráfico de voz necesita una transmisión estable, con poco retardo y poca pérdida de paquetes.

# Question 6 / Pregunta 6

**English: An insurance company is using public cloud computing for one of its critical applications to reduce costs. Which of the following would be of MOST concern to the IS auditor?**

A. The inability to recover the service in a major technical failure scenario

B. The data in the shared environment being accessed by other companies

C. The service provider not including investigative support for incidents

D. The long-term viability of the service if the provider should go out of business

**Español: Una aseguradora utiliza una nube pública para una aplicación crítica a fin de reducir costos. ¿Qué preocuparía MÁS al auditor de SI?**

A. No poder recuperar el servicio ante una falla técnica importante.

B. Que otras empresas accedan a los datos del entorno compartido.

C. Que el proveedor no incluya apoyo para investigar incidentes.

D. La viabilidad a largo plazo del servicio si el proveedor deja de operar.

## Correct answer / Respuesta correcta: B

**Explanation of every option / Justificación de cada alternativa**

### A. Incorrect / Incorrecta

**English:** Benefits of cloud computing are redundancy and the ability to access systems and data in the event of a technical failure.

**Español:** Entre los beneficios de la computación en la nube se encuentran la redundancia y la capacidad de acceder a sistemas y datos ante una falla técnica.

### B. Correct / Correcta

**English:** Considering that an insurance company must preserve the privacy/confidentiality of customer information, unauthorized access to information and data leakage are the major concerns.

**Español:** Una aseguradora debe preservar la privacidad y confidencialidad de la información de sus clientes; por ello, el acceso no autorizado y la filtración de datos son las preocupaciones principales.

### C. Incorrect / Incorrecta

**English:** The ability to investigate an incident is important, but most important is addressing the risk of an incident: the exposure of sensitive data.

**Español:** Poder investigar un incidente es importante, pero lo más importante es abordar el riesgo de que ocurra: la exposición de datos sensibles.

### D. Incorrect / Incorrecta

**English:** If a cloud provider goes out of business, the data should still be available from backups.

**Español:** Si el proveedor de nube deja de operar, los datos deberían seguir disponibles mediante respaldos.

## Suggested speaking script / Guion sugerido

**English:** I choose B because exposing customers' confidential information is the greatest concern in this shared cloud environment.

**Español:** Elegiría la B porque exponer información confidencial de los clientes es la mayor preocupación en este entorno de nube compartido.

# Question 7 / Pregunta 7

**English: Which of the following BEST determines whether complete encryption and authentication protocols for protecting information while being transmitted exist?**

A. A digital signature with Rivest-Shamir-Adleman (RSA) has been implemented.

B. Work is being done in tunnel mode with the nested services of authentication header (AH) and encapsulating security payload (ESP).

C. Digital certificates with RSA are being used.

D. Work is being done in transport mode with the nested services of AH and ESP.

**Español: ¿Qué opción permite determinar MEJOR si existen protocolos completos de cifrado y autenticación para proteger la información durante su transmisión?**

A. Se implementó una firma digital con RSA.

B. Se opera en modo túnel con servicios anidados de encabezado de autenticación (AH) y carga de seguridad encapsulada (ESP).

C. Se utilizan certificados digitales con RSA.

D. Se opera en modo transporte con servicios anidados de AH y ESP.

## Correct answer / Respuesta correcta: B

**Explanation of every option / Justificación de cada alternativa**

### A. Incorrect / Incorrecta

**English:** A digital signature provides authentication and integrity.

**Español:** Una firma digital proporciona autenticación e integridad.

### B. Correct / Correcta

**English:** Tunnel mode provides encryption and authentication of the complete (Internet Protocol) IP package. To accomplish this, the authentication header (AH) and encapsulating security payload (ESP) services can be nested.

**Español:** El modo túnel proporciona cifrado y autenticación del paquete IP completo. Para lograrlo, pueden anidarse los servicios AH y ESP.

### C. Incorrect / Incorrecta

**English:** A digital certificate provides authentication and integrity.

**Español:** Un certificado digital proporciona autenticación e integridad.

### D. Incorrect / Incorrecta

**English:** The transport mode provides primary protection for the protocols' higher layers (i.e., protection extends to the data field [payload] of an IP package).

**Español:** El modo transporte proporciona protección principalmente a las capas superiores de los protocolos; es decir, la protección abarca el campo de datos o carga útil de un paquete IP.

## Suggested speaking script / Guion sugerido

**English:** I choose B because tunnel mode protects the entire original IP packet using the specified security services.

**Español:** Elegiría la B porque el modo túnel protege todo el paquete IP original mediante los servicios de seguridad indicados.

# Question 8 / Pregunta 8

**English: Which of the following concerns about the security of an electronic message would be addressed by digital signatures?**

A. Alteration

B. Unauthorized reading

C. Theft

D. Unauthorized copying

**Español: ¿Cuál de las siguientes preocupaciones sobre la seguridad de un mensaje electrónico se aborda mediante firmas digitales?**

A. Alteración.

B. Lectura no autorizada.

C. Robo.

D. Copia no autorizada.

## Correct answer / Respuesta correcta: A

**Explanation of every option / Justificación de cada alternativa**

### A. Correct / Correcta

**English:** A digital signature includes an encrypted hash total of the size of the message as it was transmitted by its originator. This hash would no longer be accurate if the message were subsequently altered, indicating that the alteration had occurred.

**Español:** Una firma digital incluye un valor hash cifrado del tamaño del mensaje tal como fue transmitido por su emisor. Ese hash dejaría de ser correcto si el mensaje se alterara posteriormente, indicando que hubo una modificación.

### B. Incorrect / Incorrecta

**English:** Digital signatures will not identify, prevent or deter unauthorized reading.

**Español:** Las firmas digitales no identifican, evitan ni disuaden la lectura no autorizada.

### C. Incorrect / Incorrecta

**English:** Digital signatures will not identify, prevent or deter theft.

**Español:** Las firmas digitales no identifican, evitan ni disuaden el robo.

### D. Incorrect / Incorrecta

**English:** Digital signatures will not identify, prevent or deter unauthorized copying.

**Español:** Las firmas digitales no identifican, evitan ni disuaden las copias no autorizadas.

**Nota del material original:** La clave describe el hash como referido al tamaño del mensaje; se conserva esa redacción. Técnicamente, se calcula sobre el contenido del mensaje.

## Suggested speaking script / Guion sugerido

**English:** I choose A because verification of the digital signature can reveal that the message was changed.

**Español:** Elegiría la A porque verificar la firma digital permite descubrir que el mensaje fue modificado.

# Question 9 / Pregunta 9

**English: Which of the following characterizes a distributed denial of service (DDoS) attack?**

A. Central initiation of intermediary computers to direct simultaneous spurious message traffic at a specified target site

B. Local initiation of intermediary computers to direct simultaneous spurious message traffic at a specified target site

C. Central initiation of a primary computer to direct simultaneous spurious message traffic at multiple target sites

D. Local initiation of intermediary computers to direct staggered spurious message traffic at a specified target site

**Español: ¿Qué caracteriza un ataque distribuido de denegación de servicio (DDoS)?**

A. Activación central de computadoras intermediarias para dirigir simultáneamente tráfico de mensajes espurios a un sitio objetivo específico.

B. Activación local de computadoras intermediarias para dirigir simultáneamente tráfico de mensajes espurios a un sitio objetivo específico.

C. Activación central de una computadora principal para dirigir simultáneamente tráfico de mensajes espurios a varios sitios objetivo.

D. Activación local de computadoras intermediarias para dirigir tráfico de mensajes espurios de forma escalonada a un sitio objetivo específico.

## Correct answer / Respuesta correcta: A

**Explanation of every option / Justificación de cada alternativa**

### A. Correct / Correcta

**English:** This best describes a distributed denial of service (DDoS) attack. Such attacks are centrally initiated and involve the use of multiple compromised computers. The attacks work by flooding the target site with spurious data, thereby overwhelming the network and other related resources. To achieve this objective, the attacks need to be directed at a specific target and occur simultaneously.

**Español:** Esta opción describe mejor un ataque DDoS. Los ataques se inician de forma centralizada y utilizan varias computadoras comprometidas. Inundan el sitio objetivo con datos espurios, saturando la red y otros recursos relacionados. Para lograrlo, deben dirigirse a un objetivo específico y ocurrir simultáneamente.

### B. Incorrect / Incorrecta

**English:** DDoS attacks are not locally initiated.

**Español:** Los ataques DDoS no se inician localmente.

### C. Incorrect / Incorrecta

**English:** DDoS attacks are not initiated using a primary computer.

**Español:** Los ataques DDoS no se inician utilizando una computadora principal.

### D. Incorrect / Incorrecta

**English:** DDoS attacks are not staggered.

**Español:** Los ataques DDoS no ocurren de forma escalonada.

### Suggested speaking script / Guion sugerido

**English:** I choose A because many compromised devices simultaneously flood the same target under coordinated control.

**Español:** Elegiría la A porque numerosos equipos comprometidos saturan simultáneamente el mismo objetivo mediante un control coordinado.

# Question 10 / Pregunta 10

**English: Which of the following is the MOST effective preventive antivirus control?**

A. Scanning email attachments on the mail server

B. Restoring systems from clean copies

C. Disabling universal serial bus (USB) ports

D. An online antivirus scan with up-to-date virus definitions

**Español: ¿Cuál es el control antivirus preventivo MÁS eficaz?**

A. Analizar los archivos adjuntos de correo en el servidor de correo.

B. Restaurar sistemas a partir de copias limpias.

C. Desactivar los puertos USB.

D. Un análisis antivirus en línea con definiciones de virus actualizadas.

## Correct answer / Respuesta correcta: C

**Explanation of every option / Justificación de cada alternativa**

### A. Incorrect / Incorrecta

**English:** Scanning email attachments on the mail server is a preventive control. It will prevent infected email files from being opened by the recipients, which would cause their machines to become infected.

**Español:** Analizar los archivos adjuntos en el servidor de correo es un control preventivo. Evita que los destinatarios abran archivos de correo infectados que infectarían sus equipos.

### B. Incorrect / Incorrecta

**English:** Restoring systems from clean copies is a preventive control. It will ensure that viruses are not introduced from infected copies or backups, which would reinfect machines.

**Español:** Restaurar los sistemas desde copias limpias es un control preventivo. Garantiza que no se introduzcan virus desde copias o respaldos infectados que volverían a infectar los equipos.

### C. Correct / Correcta

**English:** Disabling universal serial bus (USB) ports is a preventive control. It prevents infected files from being copied from a USB drive onto a machine, which would cause the machine to become infected.

**Español:** Desactivar los puertos USB es un control preventivo. Evita copiar archivos infectados desde una unidad USB a un equipo, lo que provocaría su infección.

### D. Incorrect / Incorrecta

**English:** Antivirus software can be used to prevent virus attacks. Running regular scans can is useful to detect virus infections that have already occurred. Regular updates of the software are required to ensure it can update, detect and treat viruses as they emerge.

**Español:** El software antivirus puede utilizarse para prevenir ataques de virus. Los análisis regulares son útiles para detectar infecciones que ya ocurrieron. Se necesitan actualizaciones periódicas para que pueda actualizarse, detectar y tratar los virus a medida que aparecen.

**Nota del material original:** La clave resalta C. A y B también se describen como controles preventivos; se conserva la explicación de cada alternativa.

## Suggested speaking script / Guion sugerido

**English:** I choose C according to the supplied key, because disabling USB ports blocks the transfer of infected files through that route.

**Español:** Elegiría la C según la clave proporcionada, porque desactivar los puertos USB bloquea la transferencia de archivos infectados por esa vía.